Data Privacy and GDPR Compliance Policy

Policy ID: POL-PRV-002 | Version 1.0 | Classification: Internal

Policy Owner	Data Protection Officer / Chief Privacy Officer	**Effective Date**	12 September 2026
Review Cycle	At least annually and upon material legal, threat, technology, or business change	**Approval Authority**	Executive Risk / Information Security Governance Committee
Applies To	Enterprise workforce, controlled entities, and in-scope suppliers	**Control Status**	Mandatory unless formally excepted

Mandatory language: "MUST" and "MUST NOT" indicate mandatory requirements. "SHOULD" indicates an expected control that may be varied only when a risk-based alternative is documented. "Strictly Prohibited" identifies conduct that is not permitted absent an explicit, legally valid emergency or exception pathway.

1. Objective

This policy defines mandatory requirements for lawful, fair, transparent, secure, and accountable processing of personal data. It establishes privacy-by-design obligations and technical controls for the full information lifecycle, from collection through deletion. The enterprise will process personal data only for documented purposes, under a valid legal basis, with appropriate safeguards proportionate to risk.

2. Scope

This policy applies to all business units, legal entities, systems, employees, contractors, suppliers, processors, subprocessors, applications, databases, analytics platforms, logs, AI systems, development environments, and records that collect, infer, store, transmit, access, disclose, or delete personal data relating to customers, prospects, employees, applicants, partners, website users, or other individuals.

3. Governance, Accountability, and Roles

Data Protection Officer. Provides independent oversight, regulatory advice, DPIA consultation, and escalation for high-risk processing.

Data Owners. Define purpose, lawful basis, retention, access, and permitted disclosures for datasets.

Engineering / Product. Implements privacy by design/default, data minimization, deletion, access controls, and auditable consent/preferences where applicable.

Security. Implements Article 32-aligned technical and organizational measures and supports breach assessment.

Procurement. Ensures processors are assessed and contracts contain required data-protection terms.

4. Policy Rules and Mandatory Guidelines

- Personal data MUST be processed in accordance with documented purpose limitation, data minimization, accuracy, storage limitation, integrity/confidentiality, fairness, transparency, and accountability principles.
- A business owner MUST document a valid lawful basis before processing begins. Consent MUST NOT be used when another basis is more appropriate or where consent cannot be freely given, specific, informed, and withdrawable.
- Special-category data and criminal-offence data require enhanced legal review and controls. Collection is Strictly Prohibited unless an applicable legal condition and documented business necessity exist.
- Products MUST default to the least privacy-invasive configuration. Optional collection, telemetry, profiling, advertising, or model-training uses MUST be disabled by default where law, contract, or enterprise policy requires opt-in.

- A Record of Processing Activities (ROPA) MUST be maintained for covered processing, including purposes, categories of data and data subjects, recipients, transfers, retention, and security measures.
- High-risk processing, systematic monitoring, large-scale sensitive-data processing, innovative technologies with material privacy risk, or processing likely to result in high risk to individuals MUST undergo a Data Protection Impact Assessment before production use.
- Data subject requests for access, correction, deletion, restriction, objection, portability, or consent withdrawal MUST be routed to the approved privacy workflow immediately. Employees MUST NOT ignore, privately answer, or delay a request outside the workflow.
- Personal data MUST NOT be retained indefinitely. Every production dataset MUST have a documented retention or deletion rule. Legal holds supersede normal deletion only for the scope and duration authorized by Legal.
- Personal data MUST NOT be copied into personal email, consumer cloud storage, unapproved SaaS, public paste services, unmanaged devices, or removable media. Export to local workstations requires explicit business need and endpoint controls.
- Production personal data MUST NOT be used in development, test, demonstration, or training environments unless it is anonymized, strongly pseudonymized with access separation, or specifically approved due to a documented technical need.
- International transfers MUST use an approved legal mechanism and transfer-risk process where required. Teams MUST NOT assume that encryption alone creates a lawful transfer.
- Processor and subprocessor relationships MUST be governed by written contractual terms defining subject matter, duration, purpose, data types, confidentiality, security, breach notification, deletion/return, assistance, and audit rights as applicable.

5. Technical and Coding Constraints

- Sensitive personal data at rest MUST be encrypted using enterprise-approved cryptography. Data in transit over untrusted or shared networks MUST use TLS 1.3 by default; TLS 1.2 MAY be used only when required for interoperability and configured with approved cipher suites. TLS 1.0, TLS 1.1, SSL, plaintext HTTP, FTP, and Telnet are prohibited for personal data.
- Applications MUST enforce server-side authorization for every request involving personal data. Client-side hiding of fields is not an access-control mechanism.
- Direct identifiers SHOULD be tokenized or pseudonymized when the business process does not require the raw value. Re-identification keys MUST be stored separately and access-limited.
- Application and analytics logs MUST minimize personal data. Credentials, authentication tokens, full payment-card data, private cryptographic material, government identifiers, health data, and other high-risk attributes MUST NOT be written to general-purpose logs.
- Database exports containing personal data MUST be access-controlled, encrypted, time-limited, and automatically deleted when the business task completes. Ad hoc exports MUST be auditable.
- APIs returning personal data MUST implement object-level and function-level authorization, rate limiting, schema validation, and anti-enumeration controls. Sequential IDs MUST NOT be assumed confidential.
- Deletion must propagate to primary systems, caches, search indexes, replicas, and downstream processors according to the approved retention design. Backup deletion may follow controlled expiry cycles where immediate selective deletion is technically infeasible, provided restored data is re-subjected to deletion rules.
- Privacy-sensitive configuration and consent events MUST be logged with timestamp, source, version, and relevant policy/notice context sufficient to demonstrate accountability without unnecessarily storing additional personal data.

6. Operational Control Requirements

- Suspected personal-data breaches MUST be immediately reported to the incident-response and privacy teams. Breach assessment MUST determine data categories, affected people, likely consequences, containment, and

regulatory/individual notification obligations. Where GDPR Article 33 applies, the controller must be positioned to notify the supervisory authority within 72 hours after becoming aware, unless the breach is unlikely to result in risk to rights and freedoms.

- Privacy reviews MUST be integrated into new-product, new-vendor, material-change, AI use-case, tracking technology, data-sharing, and cross-border transfer approval processes.
- Data owners MUST conduct at least annual reviews of high-risk datasets, access, retention, processors, and purpose compatibility.

7. Monitoring, Assurance, and Records

Compliance with this policy MUST be demonstrable. Evidence is part of the control, not an optional administrative artifact. Records MUST be retained according to the enterprise records-retention schedule, legal holds, applicable regulation, and contractual requirements.

Minimum expected records:

- ROPA entries
- DPIAs and legitimate-interest assessments
- Consent/preference evidence
- Data subject request records
- Processor assessments and DPAs
- Transfer assessments
- Retention schedules
- Breach assessment records

Security, Internal Audit, Privacy, Legal, Compliance, and authorized risk functions MAY request evidence and perform sampling or technical validation. System owners MUST provide accurate evidence and MUST NOT suppress, alter, or fabricate control records.

8. Enforcement and Violation Consequences

Non-compliance may result in immediate suspension of processing, deletion or quarantine of unlawfully collected data, access revocation, mandatory corrective action, disciplinary measures, supplier remedies, customer notification where required, regulatory escalation, or other legal action. Intentional misuse, unauthorized disclosure, concealment of a breach, or circumvention of consent or privacy controls is considered serious misconduct.

Where a violation creates active risk, protective action may occur before disciplinary or contractual review is complete. Enforcement decisions will consider intent, recurrence, severity, impact, legal duties, and whether the individual promptly reported the issue and cooperated with remediation.

9. Exceptions and Risk Acceptance

Privacy exceptions are permitted only where lawful and necessary. An exception MUST identify the specific requirement, legal basis, processing purpose, affected data, risk assessment, safeguards, accountable owner, DPO/Privacy approval, Security approval where technical controls are reduced, and a fixed expiration date. No exception may waive statutory rights or regulatory obligations.

An exception MUST NOT be interpreted as permanent policy change. The control owner may require additional monitoring, narrower scope, remediation milestones, or earlier review. Expired exceptions automatically cease to authorize the deviation.

10. Standards and Regulatory Alignment

This policy is designed to support the enterprise ISMS and cybersecurity risk program. Mappings are implementation aids; they do not replace a formal applicability analysis, legal advice, or the authoritative standards and regulations.

Framework	Policy alignment
ISO/IEC 27001:2022	Supports risk assessment, information classification, access control, supplier assurance, logging, deletion, incident management, and protection of records within the ISMS.
NIST CSF 2.0	GV.RR roles; GV.PO policy; ID.AM data inventories; PR.DS data security; PR.AA identity/access; DE.CM monitoring; RS.MA incident management; RC recovery.
GDPR	Direct alignment to Articles 5, 6, 12-22, 25, 28, 30, 32-35, and Chapter V as applicable to the processing context.

Authoritative reference set

- ISO/IEC 27001:2022, Information security, cybersecurity and privacy protection - Information security management systems - Requirements. This policy supports the ISMS risk-management model and applicable Annex A controls without reproducing proprietary standard text.
- NIST Cybersecurity Framework (CSF) 2.0, NIST CSWP 29 (2024). Control outcomes are organized across GOVERN, IDENTIFY, PROTECT, DETECT, RESPOND, and RECOVER as applicable.
- Regulation (EU) 2016/679 (General Data Protection Regulation, GDPR), including the principles of Article 5 and, where applicable, Articles 6, 25, 28, 30, 32, 33, 34, 35, and Chapter V on international transfers.

11. Review, Maintenance, and Approval

The policy owner MUST review this document at least annually and whenever a material incident, audit finding, law/regulation, technology change, threat development, merger/acquisition, or operating-model change may affect its adequacy. Proposed changes MUST be version-controlled and approved through the enterprise policy governance process. Local procedures may impose stricter requirements but MUST NOT weaken this policy without an approved exception.

End of controlled document.